

Projeto de Bloco - TP2

E-ComShield | Análise exploratória e segurança da API
Autores: Nathalia Calazans Artigas e Daniel Augusto da Silva
27 de setembro de 2026

Recursos do projeto

[Repositório na main](#) | [Relatório ZAP e triagem](#) | [Exportação ZAP \(HTML\)](#)
[Relatório completo da EDA](#)

Problema e objetivo

Aprofundar a análise de textos de e-commerce com correlação, visualizações e teste de hipótese formal; verificar os controles de segurança da API FastAPI e registrar um scan passivo real do OWASP ZAP. O B2W fornece avaliações reais em português, enquanto o Bitext fornece rótulos de intenção publicados pela fonte.

Fontes e separação metodológica

Fonte	Papel na análise	Volume após preparo
Bitext Retail eCommerce	EDA das intenções originais; base de treino do baseline	44.884 textos; 46 intenções; 13 categorias
B2W-Reviews01	Feedback real em PT-BR; hipótese de comprimento do texto	132.373 linhas originais; 131.347 após limpeza
Amostra B2W anotada	Validação externa futura, sem contaminar o treino	500 rótulos humanos; 422 elegíveis sem marca de incerteza

Regra importante: a nota do B2W não é rótulo de intenção. O projeto não usa as antigas heurísticas de palavras-chave como ground truth. O Bitext é inglês e híbrido/sintético; a avaliação PT-BR humana permanece separada do treinamento.

Reprodutibilidade

- Downloads fixados por revisão e SHA-256; scripts verificam a integridade antes da EDA.
- Partições do Bitext determinísticas, estratificadas por intenção e sem texto idêntico entre treino e teste.
- Notebooks 03 e 04 contêm a EDA executada; o relatório completo está em [reports/tp2_data_eda/relatorio.md](#).

EDA aprofundada: correlações e relações

O heatmap usa Spearman para atributos numéricos do Bitext: comprimentos de solicitação e resposta, em caracteres e palavras, e presença de interrogação. Intenção e categoria são nominais e não foram convertidas em números arbitrários.

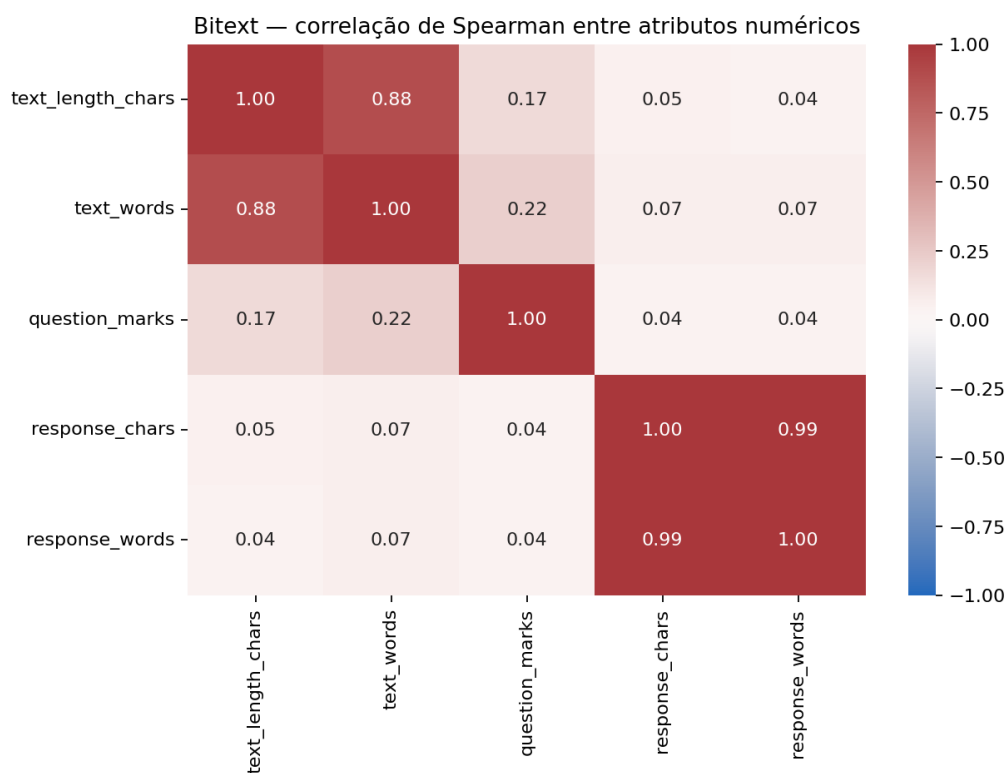


Figura 1. Correlações de Spearman no Bitext.

Caracteres e palavras da solicitação têm correlação aproximada de 0,88; as duas medidas da resposta, 0,99. A correlação entre comprimento de solicitação e resposta é apenas 0,05. As duas primeiras associações são em grande parte mecânicas; nenhuma delas demonstra causalidade ou qualidade do classificador.

EDA aprofundada: dispersões

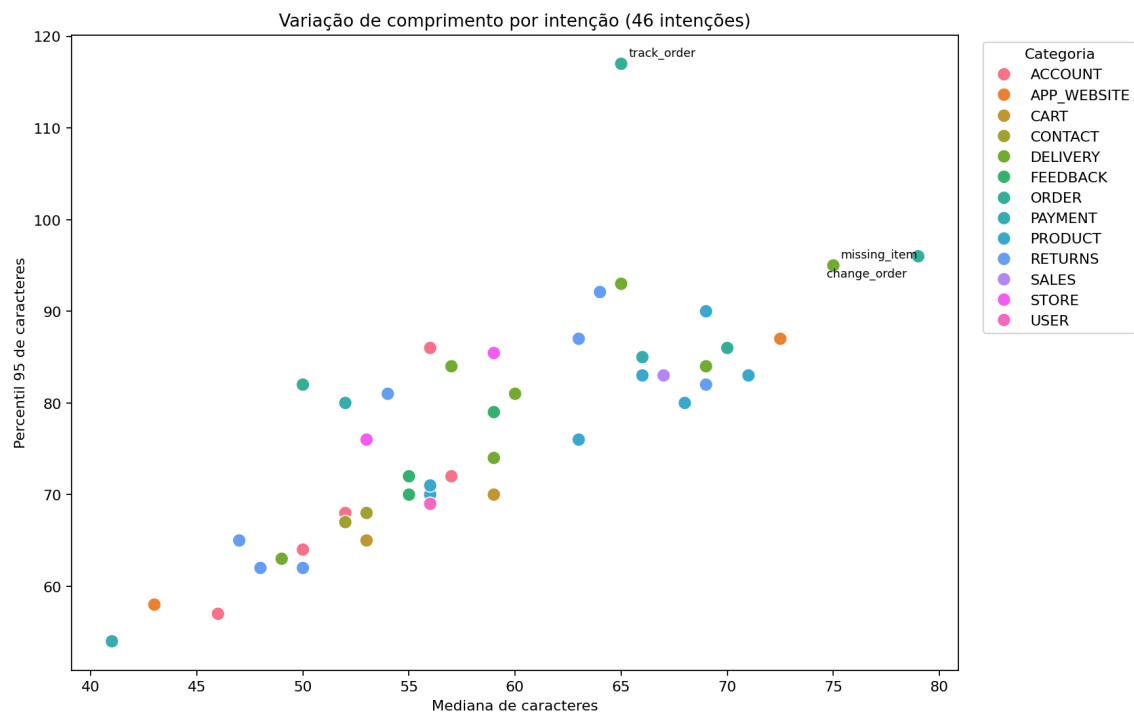


Figura 2. Mediana e percentil 95 do comprimento por intenção.

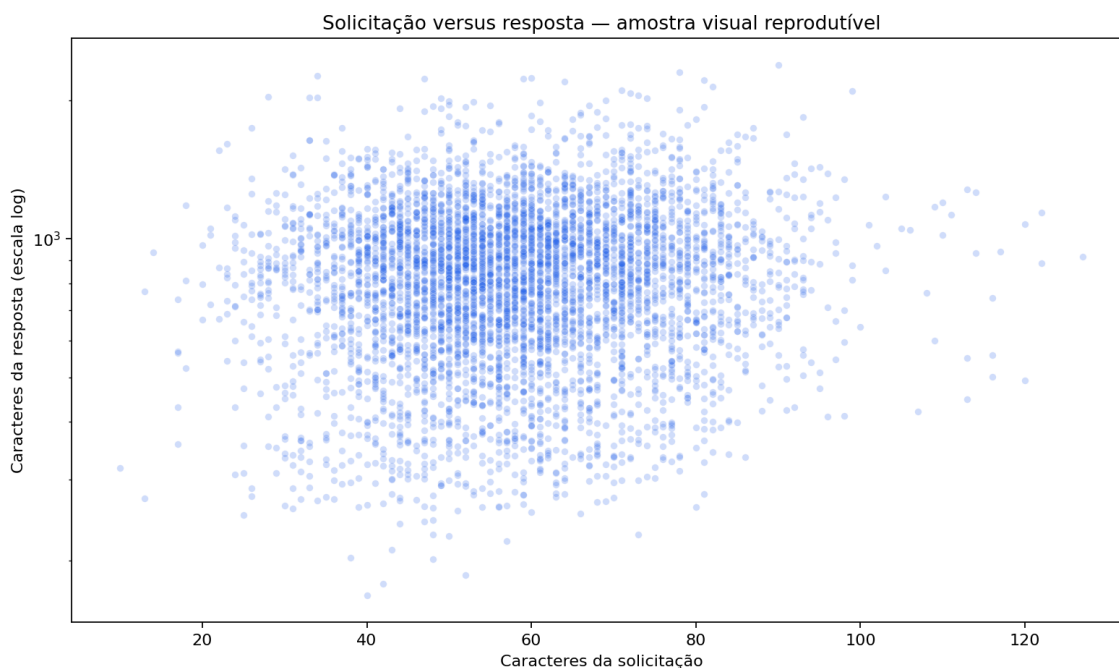


Figura 3. Comprimento da solicitação versus resposta em amostra reprodutível de 5.000 linhas.

O primeiro gráfico cobre as 46 intenções. Em `track_order`, o percentil 95 chega a 117 caracteres, contra 84 no conjunto. O segundo gráfico usa `random_state=42` para legibilidade visual; as estatísticas são calculadas com todas as linhas elegíveis.

Hipótese formal no B2W

Hipótese do TP1: avaliações negativas tendem a ter textos mais longos. Comparamos notas 1-2 com notas 4-5, excluindo nota 3. Aplicamos Mann-Whitney U unilateral (aproximação assintótica, com correção de empates) porque os comprimentos são assimétricos.

Análise	n (notas 1-2 / 4-5)	Medianas	p unilateral	Efeito
Todas as avaliações	35.020 / 80.111	154 / 102 caracteres	$< 10^{-300}$	P(superioridade)=0,6771
Primeira por revisor	31.313 / 69.028	154 / 102 caracteres	$< 10^{-300}$	P(superioridade)=0,6762

No teste principal, $U=1.899.459.581,5$; a diferença descritiva entre medianas é 52 caracteres. A probabilidade de superioridade de 0,6771 significa que, em pares de grupos diferentes, o texto de nota baixa tende a ser mais longo em cerca de 67,7% das comparações, contando empates pela metade. O p-valor não é zero.

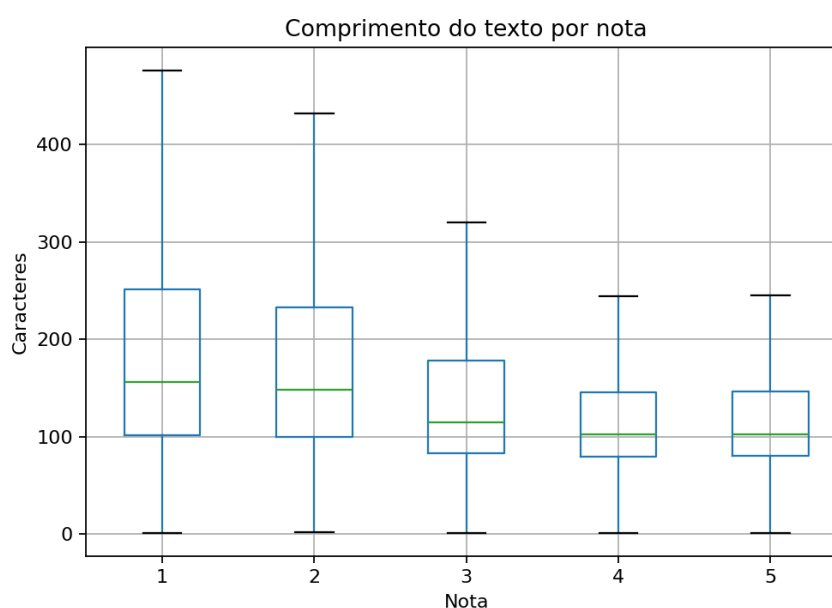


Figura 4. Comprimento dos feedbacks por nota no B2W.

A sensibilidade por primeira avaliação cronológica de cada revisor preserva quase todo o efeito. Este teste é exploratório: a hipótese foi formulada após olhar o TP1, e fatores de produto ou perfil do revisor podem confundir a associação. Mann-Whitney não prova, por si só, uma diferença causal ou de medianas.

API e controles OWASP

Controle	Implementação e evidência
Validação	Modelos de entrada Pydantic com extra='forbid'; campos inesperados retornam 422.
Persistência e BOLA	SQLModel com PostgreSQL e consultas ORM parametrizadas, sem SQL bruto; leituras por ID em usuários, avaliações, reembolsos e previsões exigem dono ou administrador.
Headers e CORS	HSTS, X-Frame-Options, X-Content-Type-Options e CSP; origens CORS em allowlist explícita.
Brute force	POST /auth/token: 5 tentativas por IP em janela móvel de 60 segundos; resposta 429 com Retry-After.

Autorização por objeto e identidade

As rotas de detalhe com identificador não aceitam apenas um token válido: comparam o usuário autenticado com o dono do registro (ou exigem perfil administrador). As listagens também são filtradas por escopo. O cadastro público cria somente usuários viewer; tentativa de enviar role extra é rejeitada com 422. Usuários desativados não obtêm nem reutilizam token.

Headers e acesso entre origens

O middleware emite HSTS, X-Frame-Options, X-Content-Type-Options e Content-Security-Policy. O CORS não usa curinga: responde às origens autorizadas na configuração. HSTS é relevante quando o serviço é publicado atrás de HTTPS; o teste local em HTTP verifica o cabeçalho, não uma conexão TLS.

Justificativa e limite do rate limiting

Cinco tentativas por minuto reduzem rajadas de tentativa de senha e ainda toleram poucos erros de digitação. É uma escolha para demonstração local, não garantia universal: o contador fica na memória, reinicia com o processo, não é compartilhado entre workers e une usuários atrás do mesmo IP/NAT. Produção exige armazenamento compartilhado, tratamento de proxy/IP e monitoramento.

Testes de segurança e evidência de execução

A suíte automatizada foi executada com **pytest tests/ -q**: 16 testes passaram. Os cenários centrais estão identificados abaixo; respostas 401/403/422 são asserções dos testes, não inferências do scan ZAP.

Cenário de segurança	Requisição/asserção	Resultado
Sem token	GET /users/me e GET /refunds/ sem Authorization	401
Objeto de outro usuário	Usuário A consulta /users/{id} e /refunds/{id} de B	403
Campo extra no corpo	POST /auth/register com campo não declarado	422

Cobertura complementar

- Leitura privada de avaliações e predições também retorna 403 ao usuário errado.
- Cadastro público não permite atribuir perfil admin; contas desativadas não fazem login nem reutilizam token.
- A sexta tentativa de autenticação na janela retorna 429; o teste verifica Retry-After.
- Headers, allowlist CORS e recursos estáticos locais da documentação têm verificações próprias.

Teste manual com banco persistente

Em PostgreSQL 16.15, um recurso criado por B retornou 403 para A, 200 para B e 401 sem token. Após reiniciar a API, o registro continuou acessível para B. Esse smoke test complementa os testes automatizados; não equivale a uma auditoria completa de todas as rotas e perfis.

Código da suíte: [tests/test_security.py](#) e [tests/test_api.py](#).

OWASP ZAP: scan passivo real

OWASP ZAP 2.17.0 executado localmente em 26/09/2026, 22h37, contra <http://127.0.0.1:8000>. Foram importadas 17 URLs pela especificação OpenAPI. O scan foi **passivo e sem autenticação**; os relatórios HTML e JSON foram exportados após a conclusão da execução.

Severidade	Tipos de alerta	Tratamento
Alta	0	Nenhum alerta desta severidade na varredura.
Média	1	Alerta 10055 analisado abaixo; risco aceito no ambiente local.
Baixa	2	Alertas de metadados em bundles estáticos; contexto registrado no relatório.
Informativa	3	Observações documentadas na exportação integral.

Alerta médio 10055: CSP style-src 'unsafe-inline' em /docs

Deteção: o ZAP encontrou a diretiva **unsafe-inline** para estilos na página Swagger. **Problema:** se outra falha permitir injetar conteúdo nessa página, estilos maliciosos podem ser aplicados. **Decisão:** risco aceito para a demonstração local, **não corrigido**. O Swagger usa estilos dinâmicos e a compatibilidade de sua remoção não foi comprovada. A exceção é restrita a /docs; scripts continuam limitados à origem e a hash específico. Antes de publicação pública, restringir /docs ou testar uma UI com CSP mais estrita.

Escopo da conclusão

Zero alertas altos neste scan não demonstra ausência de vulnerabilidades. A varredura sem login não explorou objetos de usuários diferentes e não valida BOLA; os testes de autorização da página anterior oferecem essa evidência separadamente.

Evidências: [triagem por alerta](#); [exportação HTML](#); [exportação JSON](#).

Síntese da EDA e continuidade

Insights principais

- A associação entre comprimento de solicitação e resposta no Bitext é fraca (Spearman aproximadamente 0,05); tamanho da entrada não é proxy simples para o tamanho da resposta.
- No B2W, notas 1-2 acompanham textos mais longos que notas 4-5; a análise por primeira avaliação de cada revisor preserva o efeito, mas não estabelece causa.
- Os 500 rótulos PT-BR foram revisados um a um: 375 concordâncias iniciais, 125 adjudicações, 78 casos incertos e 422 elegíveis para avaliação futura. Kappa inicial de 0,5504; apenas 20 das 46 intenções aparecem na amostra.

Limitações

- O Bitext é inglês e híbrido/sintético; frequências e métricas internas não representam automaticamente chamados reais em português.
- O B2W contém avaliações de produto de 2018, não chamados de suporte com intenção original.
- A amostra humana de 500 é estratificada por nota; 78 casos incertos ficam fora da métrica principal. Não deve estimar a distribuição natural do atendimento.
- 84 decisões de adjudicação não registram justificativa textual; a cobertura de intenções limita uma conclusão forte de generalização.

Próximos passos para o classificador

Executar avaliação externa sobre as 422 linhas elegíveis, com métricas por intenção e análise de erro; ampliar cobertura e qualidade das justificativas de anotação; somente depois integrar um modelo validado. O Macro-F1 interno do Bitext (0,9887) não mede desempenho PT-BR. /predictions/predict ainda usa resposta placeholder.

Referências e materiais suplementares

Código, notebooks e relatórios: [repositório na main](#).

Findings detalhados: [relatório OWASP ZAP](#).

Exportação da ferramenta: [relatório ZAP em HTML](#).

EDA estruturada: [relatório TP2 de dados](#).

Arquivos de análise e verificação

Item	Arquivo versionado
EDA B2W	notebooks/03_b2w_feedback_eda.ipynb
EDA Bitext	notebooks/04_bitext_intent_eda.ipynb
Validação PT-BR	notebooks/06_ptbr_validated_dataset_eda.ipynb
Testes da API	tests/test_security.py
Relatório EDA	reports/tp2_data_eda/relatorio.md
ZAP original	reports/zap_report.html e JSON

Fontes dos dados: [B2W-Reviews01](#) (CC BY-NC-SA 4.0); [Bitext Retail eCommerce](#) (CDLA-Sharing-1.0).

Os dados brutos não integram o repositório devido ao tamanho e às condições de uso. Os scripts de download e verificação permitem reproduzir a análise.